RGPD et IA générative : guide pédagogique pour les entreprises

1. Comprendre les principes fondamentaux du RGPD

Le règlement (UE) 2016/679, dit RGPD, fixe un cadre commun de protection des données personnelles pour toutes les organisations qui traitent des informations relatives à des personnes physiques dans l'Union européenne. Il repose sur plusieurs principes clés que chaque entreprise doit intégrer dans sa gouvernance des données.[1][2]

Les principaux principes figurent à l'article 5 du RGPD : licéité, loyauté et transparence ; limitation des finalités ; minimisation des données ; exactitude ; limitation de la conservation ; intégrité et confidentialité ; responsabilité (accountability). La CNIL rappelle que ces principes s'appliquent pleinement aux systèmes d'intelligence artificielle lorsqu'ils impliquent des données personnelles.[3][4][^2]

Licéité, loyauté, transparence

Un traitement ne peut être mis en œuvre que s'il repose sur une base légale valide (consentement, contrat, obligation légale, intérêt légitime, etc.). L'entreprise doit informer clairement les personnes concernées (clients, salariés, prospects) sur l'usage de leurs données, notamment lorsque celles-ci alimentent un modèle d'IA.[2][5][6][7][^8]

La loyauté implique de ne pas détourner les données de la finalité annoncée ni de recourir à des procédés trompeurs (par exemple des cases pré-cochées ou des « cookie walls » qui ne permettent pas un consentement libre). La transparence exige des mentions d'information compréhensibles, accessibles et adaptées au public visé.[5][6][^7]

Limitation des finalités et minimisation des données

Les données personnelles doivent être collectées pour des finalités déterminées, explicites et légitimes, puis ne pas être réutilisées de manière incompatible avec ces finalités. En matière d'IA, la CNIL insiste sur la nécessité de définir clairement la finalité de l'entraînement et de l'utilisation du modèle (par exemple assistance client, détection de fraude, analyse de satisfaction).[9][10][3][2]

Le principe de minimisation impose de ne collecter et de ne traiter que les données strictement nécessaires à la finalité. Cela vaut aussi pour les prompts envoyés à un chatbot ou à une IA générative : l'entreprise doit éviter d'y inclure des identifiants directs ou des informations sensibles lorsqu'elles ne sont pas indispensables.[11][8][12][2]

Exactitude, limitation de la conservation, sécurité

L'entreprise doit prendre toutes les mesures raisonnables pour maintenir les données à jour et corriger les informations inexactes. Elle doit aussi fixer des durées de conservation cohérentes avec les finalités déclarées, puis effacer ou anonymiser les données à l'issue de ces délais.[13][2] [^5]

Le principe d'intégrité et de confidentialité demande de garantir un niveau de sécurité adapté aux risques : contrôle des accès, chiffrement, journalisation, sauvegardes, gestion des incidents, etc. L'usage d'IA n'exonère pas l'entreprise de ces exigences, au contraire il peut augmenter les risques (fuite, ré-identification, biais) et nécessite des mesures renforcées.[14][15] [8][13]

Responsabilité (accountability) et protection des données dès la conception

Le RGPD impose une obligation générale de responsabilité : l'entreprise doit être en mesure de démontrer sa conformité, notamment par une documentation complète (registre de traitement, analyses d'impact, politiques, contrats). La CNIL insiste sur l'importance d'intégrer la protection des données dès la conception et par défaut dans les systèmes d'IA (privacy by design/by default).[4][16][17][8][^3]

Les lignes directrices européennes sur la protection des données dès la conception et par défaut (Guidelines 4/2019 de l'EDPB) recommandent d'intégrer des techniques comme la minimisation des données, la pseudonymisation, l'anonymisation et les technologies de confidentialité (par exemple la confidentialité différentielle) dans le cycle de vie des systèmes d'IA.[18][14]

2. Les données personnelles : définitions et exemples

Définition légale

Le RGPD définit la « donnée à caractère personnel » comme toute information se rapportant à une personne physique identifiée ou identifiable. La CNIL précise qu'il s'agit de toute information relative à une personne physique susceptible d'être identifiée, directement ou indirectement.[19][20][21][22][^23]

Une personne est identifiable dès qu'elle peut être reconnue, directement (nom, prénom, photo) ou indirectement (numéro de client, adresse IP, identifiant de connexion, données de localisation, enregistrements audio). Il suffit que l'information permette, seule ou combinée à d'autres, de remonter à une personne physique.[20][21][^24]

Exemples concrets en entreprise

Dans une entreprise, sont par exemple des données personnelles :

- Données RH : identité des salariés, coordonnées, numéro de sécurité sociale, données de paie, évaluations de performance.[21][5]

- Données clients/prospects : noms, coordonnées, historique d'achats, habitudes de navigation, identifiants de compte, réclamations.[25][5]
- Données issues des systèmes d'IA : transcriptions de conversations avec un chatbot, métadonnées de requêtes, logs applicatifs contenant des identifiants.[14][11]

Les informations concernant uniquement des personnes morales (ex. numéro SIREN d'une société sans lien avec une personne identifiée) ne sont en principe pas des données personnelles. En revanche, une adresse e-mail professionnelle nominative (ex. prenom.nom@entreprise.fr) est bien une donnée personnelle.[23][21]

Données anonymes et données pseudonymisées

Les données anonymes, au sens du RGPD, sont celles qui ne permettent plus d'identifier une personne, compte tenu des moyens raisonnablement susceptibles d'être utilisés. Le règlement ne s'applique pas au traitement d'informations réellement anonymes.[26][20]

À l'inverse, les données pseudonymisées restent des données personnelles, car il est théoriquement possible de ré-identifier les personnes en recourant aux informations supplémentaires (clé de correspondance, table de hachage, etc.). L'EDPB rappelle que pour considérer un modèle d'IA comme anonyme, la probabilité d'extraction directe de données personnelles ou de « régurgitation » d'exemples du jeu d'entraînement doit être insignifiante.[27][6][20][14]

3. Les données sensibles (catégories particulières de données)

Définition légale

Le RGPD distingue une catégorie particulière de données dites « sensibles » pour lesquelles le traitement est en principe interdit. L'article 9 vise notamment les données révélant l'origine raciale ou ethnique, les opinions politiques, les convictions religieuses ou philosophiques, l'appartenance syndicale, les données génétiques, biométriques, de santé, ou relatives à la vie sexuelle ou à l'orientation sexuelle.[28][29][30][2]

La CNIL rappelle que ces données forment une catégorie particulière de données personnelles et que leur collecte et utilisation sont, par principe, interdites sauf exceptions strictement encadrées (consentement explicite, intérêt vital, obligations légales, intérêt public important, etc.).[29][28]

Exemples et enjeux pour l'IA

Sont notamment des données sensibles :

- Dossiers médicaux, certificats d'arrêt de travail, comptes-rendus d'entretien avec la médecine du travail.[28][29]
- Données biométriques utilisées pour identifier une personne (empreintes digitales, reconnaissance faciale, gabarit vocal).[29][28]

- Opinions politiques ou religieuses exprimées dans des contenus textuels, par exemple des réponses libres dans un questionnaire.[30][28]

Dans le contexte de l'IA générative, des données sensibles peuvent être introduites dans les prompts (par exemple des informations de santé d'un salarié ou des opinions politiques d'un client) ou inférées à partir de contenus (profilage à partir d'un historique de navigation, analyse de sentiments sur des échanges). Cela accroît le niveau de risque et peut imposer la réalisation d'une analyse d'impact (AIPD).[8][11][9][14]

Exceptions et conditions de traitement

Le traitement de données sensibles n'est possible que si l'une des conditions listées à l'article 9 est remplie (consentement explicite, obligations en droit du travail ou de la sécurité sociale, sauvegarde des intérêts vitaux, motifs d'intérêt public important, médecine préventive ou du travail, santé publique, recherche scientifique ou statistique, etc.).[28][29]

Ces traitements doivent en outre être assortis de mesures de sécurité renforcées (chiffrement, pseudonymisation, contrôle d'accès strict, journalisation). La CNIL recommande de privilégier des solutions on-premise ou des infrastructures européennes pour les systèmes d'IA qui manipulent des données sensibles.[31][12][11][28]

4. Les responsabilités de l'entreprise (responsable du traitement et sous-traitants)

Responsable du traitement et sous-traitant

Le RGPD distingue le responsable du traitement (l'entité qui détermine les finalités et les moyens du traitement) et le sous-traitant (l'entité qui traite les données pour le compte du responsable). Dans une entreprise, la direction ou la structure qui décide de recourir à un système d'IA pour une finalité donnée (ex. support client) est généralement responsable du traitement.[32][16][^25]

Lorsqu'un prestataire externe fournit l'outil (éditeur de logiciel, fournisseur de cloud ou d'API d'IA), il est en principe sous-traitant au sens du RGPD, sauf lorsqu'il décide lui-même des finalités (cas de certaines plateformes opérant pour leur propre compte).[16][33]

Obligations générales du responsable du traitement

L'article 24 du RGPD impose au responsable du traitement de mettre en œuvre des mesures techniques et organisationnelles appropriées pour s'assurer et être en mesure de démontrer que le traitement est effectué conformément au règlement. Cela inclut la définition d'une politique de protection des données, la tenue d'un registre des traitements, la formation des équipes, la gestion des incidents et l'encadrement des sous-traitants.[34][17][16][8][^25]

L'article 25 impose la protection des données dès la conception et par défaut, ce qui signifie que l'entreprise doit intégrer les principes de minimisation, de sécurité et de limitation des finalités dans les paramètres par défaut des outils numériques, y compris des systèmes d'IA.[16][18]

Registre des traitements, analyses d'impact et sécurité

Les entreprises doivent tenir un registre des activités de traitement, sauf exception limitée pour les structures de moins de 250 salariés lorsqu'elles ne réalisent pas de traitements à risque. En pratique, même les petites entreprises sont encouragées par la CNIL à documenter leurs traitements, notamment ceux impliquant des systèmes d'IA.[35][17][5][25]

Une analyse d'impact relative à la protection des données (AIPD, ou DPIA) est obligatoire lorsque le traitement est susceptible d'engendrer un risque élevé pour les droits et libertés des personnes, par exemple en cas de profilage à grande échelle, d'utilisation de données sensibles ou de décisions automatisées produisant des effets juridiques importants.[36][37][^9]

L'article 32 impose au responsable du traitement et au sous-traitant de mettre en œuvre des mesures de sécurité appropriées (chiffrement, anonymisation, tests de vulnérabilité, procédures de gestion des incidents, etc.), en tenant compte de la nature des données, des risques et de l'état de l'art.[13][8]

Encadrement des sous-traitants et transferts de données

Les relations avec les prestataires (hébergeurs, éditeurs de solutions d'IA, fournisseurs de cloud) doivent être formalisées par des contrats conformes au RGPD précisant les obligations du sous-traitant, notamment en matière de sécurité, d'assistance au responsable, de confidentialité et de suppression des données en fin de contrat.[25][16][^13]

Les transferts de données en dehors de l'UE ou vers des pays ne bénéficiant pas d'une décision d'adéquation doivent être encadrés par des garanties appropriées (clauses contractuelles types, règles d'entreprise contraignantes, etc.), en cohérence avec la jurisprudence de la CJUE (notamment l'arrêt Schrems II) et les recommandations de l'EDPB.[38][26]

5. Les risques liés à l'utilisation d'une IA générative

Typologie des risques RGPD

La CNIL identifie plusieurs risques spécifiques liés aux systèmes d'IA générative : divulgation de données personnelles, production de contenus faux mais crédibles (hallucinations), opacité des modèles (« boîte noire »), biais et discriminations, et dépendance à des prestataires externes.[12][11]

L'EDPB souligne que les modèles entraînés à partir de données personnelles ne peuvent pas, par principe, être considérés comme anonymes si la probabilité d'extraction ou de régurgitation de données personnelles n'est pas insignifiante. Les organisations doivent donc considérer que le RGPD s'applique aux traitements effectués pour l'entraînement ou l'utilisation de ces modèles.[15][27][^14]

Web scraping, sources de données et base légale

Le recours au moissonnage de données (web scraping) pour entraîner des modèles d'IA pose des questions de licéité, notamment lorsque des données personnelles sont collectées à partir de sites web ou de plateformes. La CNIL et l'EDPB insistent sur le respect des robots.txt, des balises « noai », des registres d'opposition et des conditions générales d'utilisation, ainsi que sur la nécessité de documenter la base légale (souvent l'intérêt légitime) et la mise en balance associée.[39][14]

Lorsque l'entraînement ou le déploiement d'un système d'IA repose sur l'intérêt légitime, trois conditions cumulatives doivent être respectées : existence d'un intérêt réellement légitime, nécessité du traitement pour atteindre cet intérêt, et mise en balance favorable entre cet intérêt et les droits et libertés des personnes.[39][14]

Décisions automatisées et profilage

Les systèmes d'IA peuvent être utilisés pour prendre des décisions automatisées (acceptation de crédit, scoring de clients, pré-sélection de candidats, détection de fraude). Le RGPD réglemente ces traitements via l'article 22, qui accorde au personne concernée le droit de ne pas être soumise à une décision fondée exclusivement sur un traitement automatisé produisant des effets juridiques ou des effets significatifs similaires.[40][41][^36]

Des exceptions existent (contrat, loi, consentement explicite), mais elles sont strictement encadrées et impliquent des garanties supplémentaires : droit d'obtenir une intervention humaine, d'exprimer son point de vue et de contester la décision. L'EDPB et la CJUE rappellent que la simple complexité de l'algorithme ne dispense pas l'entreprise de fournir des explications utiles sur la logique sous-jacente.[42][43][41][40][^36]

Biais, discriminations et atteintes aux droits fondamentaux

Les modèles d'IA générative et de profilage peuvent reproduire ou amplifier des biais présents dans les données d'entraînement (discriminations liées au genre, à l'origine, à l'âge, etc.), ce qui peut conduire à des traitements discriminatoires et à des atteintes aux droits fondamentaux. Les autorités de protection des données insistent sur la nécessité de mettre en place des mécanismes de contrôle des biais, de correction et de supervision humaine.[18][14]

6. Les erreurs les plus fréquentes en entreprise

Confusion entre recommandations et obligations

Une erreur fréquente consiste à confondre les obligations strictes du RGPD (bases légales, information des personnes, tenue d'un registre, sécurité, gestion des sous-traitants, notification des violations) avec des recommandations ou bonnes pratiques (chartes internes, choix d'architecture technique, labels ou certifications).[17][16][^25]

Certaines recommandations de la CNIL sur l'IA (par exemple privilégier le déploiement local, limiter les prompts contenant des données sensibles, désactiver la réutilisation des prompts

par le fournisseur) ne sont pas des obligations explicites du RGPD, mais constituent des mesures prudentes pour réduire les risques et démontrer la conformité.[11][12]

Collecte excessive et détournement de finalité

De nombreuses entreprises collectent trop de données « au cas où », sans lien direct avec la finalité déclarée, ce qui contrevient aux principes de minimisation et de limitation des finalités. Il en va de même lorsqu'une base de données créée pour une finalité (ex. gestion RH) est réutilisée pour une autre (ex. entraînement d'un modèle d'IA marketing) sans base légale ni information adéquate.[44][25]

Absence de registre, de DPIA ou de DPO lorsque nécessaire

Les autorités constatent régulièrement l'absence de registre des traitements, de réalisation d'analyses d'impact pour les traitements à risque élevé (profilage, surveillance vidéo étendue, IA décisionnelle) ou de désignation de délégué à la protection des données alors que cela est requis.[37][8][^16]

Cette sous-documentation fragilise la position de l'entreprise en cas de contrôle ou d'incident, car elle ne peut pas démontrer sa conformité ni les arbitrages réalisés.[8][25]

Encadrement insuffisant des sous-traitants et des API d'IA

Une autre erreur fréquente consiste à recourir à des API publiques d'IA ou à des prestataires de cloud sans encadrer contractuellement la réutilisation des données, les mesures de sécurité et les modalités de suppression. Les entreprises doivent vérifier les engagements du prestataire, notamment en termes de localisation des données (UE ou hors UE), de réutilisation des prompts pour l'entraînement et de gestion des incidents.[11][25]

7. Les bonnes pratiques pour concilier IA générative et RGPD

Gouvernance et stratégie d'usage de l'IA

La CNIL recommande de partir d'un besoin concret, de définir une liste d'usages autorisés et interdits, et de mettre en place une gouvernance adaptée impliquant les parties prenantes (DPO, RSSI, métiers, direction). Pour l'IA générative, il est également conseillé de rédiger une charte d'usage interne précisant les types de prompts autorisés, les données interdites (sensibles, secret des affaires) et les règles de vérification des résultats.[45][12][^11]

La formation des utilisateurs est cruciale : ils doivent être sensibilisés aux limites de l'IA (hallucinations, biais, confidentialité) et encouragés à ne jamais copier-coller une sortie sans relecture et vérification.[12][11]

Choix techniques et architecture

Les autorités recommandent de privilégier des déploiements sécurisés : solutions on-premise ou cloud européen pour les données sensibles, paramétrage des outils pour désactiver, lorsque possible, la réutilisation des prompts pour l'entraînement, et segmentation des environnements de test et de production.[18][12][^11]

La mise en œuvre de techniques de protection de la vie privée (anonymisation, pseudonymisation, confidentialité différentielle, filtrage des sorties) est encouragée pour réduire les risques de ré-identification et de fuite de données.[14][18]

Processus de conformité opérationnelle

Un plan de conformité efficace comprend : inventaire des traitements impliquant l'IA, analyse de la base légale, mise en balance pour l'intérêt légitime lorsque utilisé, réalisation d'AIPD pour les cas à risque élevé, mise à jour du registre des traitements et des mentions d'information, encadrement contractuel des prestataires et préparation de procédures en cas de violation de données.[9][39][^8]

Des guides de sensibilisation au RGPD disponibles auprès de la CNIL proposent des modèles de registres, des listes de vérification et des exemples concrets pour les PME.[5][8][^25]

8. FAQ – 20 questions fréquentes en entreprise

1. Le RGPD s'applique-t-il aux systèmes d'IA générative utilisés en interne ?

Oui, dès qu'un système d'IA générative traite des données personnelles (prompts contenant des identifiants, logs, historique de conversations), le RGPD s'applique.[3][11]

2. Une donnée technique (adresse IP, identifiant de session) est-elle une donnée personnelle ?

Oui, dès lors qu'elle permet d'identifier une personne directement ou indirectement, une adresse IP ou un identifiant de session est une donnée personnelle.[20][21]

3. Les données utilisées pour entraîner un modèle d'IA peuvent-elles être anonymes ?

Elles ne sont considérées comme anonymes que si la probabilité d'extraction ou de régurgitation de données personnelles depuis le modèle est insignifiante ; à défaut, le RGPD s'applique.[15][27][^14]

4. Peut-on utiliser des données RH pour entraîner un modèle d'IA destiné au marketing ?

En principe non, sauf si une nouvelle base légale valide est mise en place et que les personnes sont clairement informées de cette nouvelle finalité ; sinon il s'agit d'un détournement de finalité.[2][39]

5. L'intérêt légitime suffit-il pour entraîner tous les modèles d'IA ?

Non, l'intérêt légitime n'est valable que si trois conditions sont réunies : intérêt réellement légitime, nécessité du traitement, et mise en balance favorable avec les droits et libertés des personnes.[39][14]

6. Quand une AIPD (analyse d'impact) est-elle obligatoire ?

Elle est requise pour les traitements à risque élevé, par exemple profilage à grande échelle, surveillance vidéo étendue, utilisation de données sensibles ou décisions automatisées ayant des effets juridiques significatifs.[36][37][^9]

7. Qu'est-ce qu'une décision « fondée exclusivement sur un traitement automatisé » ?

Il s'agit d'une décision prise sans intervention humaine significative, dont le résultat dépend entièrement d'un traitement automatisé ou d'un profilage.[46][41][^40]

8. Dans quels cas peut-on prendre des décisions automatisées significatives ?

Uniquement si la décision est nécessaire à un contrat, autorisée par la loi ou fondée sur le consentement explicite, et si des garanties supplémentaires sont mises en œuvre (information, intervention humaine, droit de contestation).[41][40]

9. Les prompts envoyés à une API d'IA sont-ils des données personnelles ?

Oui s'ils contiennent des informations identifiant une personne (nom, email, dossier, etc.) ; l'entreprise doit alors encadrer contractuellement la réutilisation des prompts et la localisation des données.[25][11]

10. Peut-on envoyer des données sensibles à une IA publique (API, service cloud grand public) ?

Les autorités recommandent fortement de l'éviter ; pour les données sensibles, un déploiement sur site ou sur une infrastructure fortement sécurisée doit être privilégié.[12][11]

11. Faut-il un consentement pour toutes les utilisations d'IA ?

Non, le consentement n'est qu'une des bases légales possibles ; souvent le contrat ou l'intérêt légitime peuvent être utilisés, mais il faut documenter le choix et respecter les conditions associées.[7][2][^39]

12. Consentement et intérêt légitime peuvent-ils se cumuler ?

Le RGPD ne prévoit pas de cumul pour une même finalité ; il faut choisir la base la plus adaptée et cohérente avec les attentes raisonnables des personnes.[7][2]

13. Quelles sont les obligations en cas de violation de données liées à l'IA ?

L'entreprise doit analyser l'incident, documenter les faits, évaluer les risques, notifier la CNIL dans les 72 heures si un risque existe pour les personnes, et informer celles-ci en cas de risque élevé.[8][25]

14. Un petit outil d'IA utilisé par un service interne nécessite-t-il un registre ?

Oui, tout traitement de données personnelles doit être recensé dans le registre, même pour un outil limité, sauf exceptions très spécifiques pour les très petites structures sans traitements à risque.[35][17]

15. La simple consultation d'un tableau de bord alimenté par l'IA est-elle un traitement ?

Oui, la simple consultation d'une base contenant des données personnelles constitue un traitement au sens du RGPD.[^6]

16. Quels sont les principaux droits des personnes face à l'IA ?

Les personnes disposent des droits d'accès, de rectification, d'effacement, de limitation, d'opposition, de portabilité, ainsi que du droit de ne pas être soumises à une décision automatisée et d'obtenir des explications utiles.[43][40][^2]

17. Faut-il informer les personnes qu'un contenu est généré par une IA ?

Le règlement sur l'IA impose des obligations de transparence, notamment la mention de l'usage de systèmes d'IA pour générer des contenus ; ces exigences s'articulent avec celles du RGPD sur l'information des personnes.[38][11]

18. Les logs techniques des systèmes d'IA doivent-ils être purgés ?

Oui, les durées de conservation des logs contenant des données personnelles doivent être limitées et cohérentes avec les finalités ; ils ne peuvent être conservés indéfiniment « au cas où ».[2][8]

19. La CNIL peut-elle contrôler spécifiquement les usages d'IA ?

Oui, elle dispose de pouvoirs de contrôle et de sanction pour tous les traitements de données personnelles, y compris ceux reposant sur des systèmes d'IA, et publie des recommandations spécifiques sur ces usages.[10][3]

20. À partir de quand le règlement européen sur l'IA s'applique-t-il ?

Le règlement européen sur l'IA est applicable progressivement à partir de 2024 ; il complète le RGPD en imposant des exigences supplémentaires pour certains systèmes (haut risque, interdits, transparence), sans le remplacer.[38][11]

9. Tableau "Ce que je peux faire / Ce que je dois éviter" (RGPD et IA générative)

Situation en entreprise (IA générative)	Ce que je peux faire (sous conditions légales)	Ce que je dois éviter
Utiliser un chatbot interne pour assister les salariés	Définir une finalité claire (support, FAQ), limiter les données collectées aux informations nécessaires, informer les salariés, paramétrer l'outil pour ne pas réutiliser les conversations à des fins incompatibles, documenter le traitement dans le registre.[3][5][^12]	Déployer un chatbot sans information ni registre, collecter toutes les conversations « au cas où », laisser le fournisseur réutiliser librement les données pour entraîner ses modèles publics.[11][44]
Tester une IA générative avec des données clients	Utiliser un environnement de test isolé, anonymiser ou pseudonymiser les données, vérifier la base légale et réaliser une AIPD si les risques sont élevés.[14][9][^8]	Importer des bases clients complètes en production sans analyse de risques, sans anonymisation, ni base légale claire, et sans encadrement contractuel du prestataire.[39][25]
Utiliser l'IA pour pré-sélectionner des candidats	Définir la finalité (tri, aide à la décision), réaliser une AIPD, garantir une intervention humaine concrète, prévoir des explications utiles et des voies de recours ; limiter les critères utilisés pour éviter les discriminations.[40][43][^36]	Confier entièrement la décision à l'algorithme sans supervision humaine, utiliser des critères opaques ou discriminatoires, ne pas informer les candidats de l'existence d'un traitement automatisé.[46][18]
Recourir à une API publique d'IA pour traiter des demandes clients	Limiter les prompts à des informations non identifiantes ou minimisées, encadrer contractuellement le prestataire (réutilisation des données, localisation des serveurs), vérifier les paramètres de confidentialité (désactivation de la réutilisation).[11][25]	Envoyer des dossiers clients complets, avec des données sensibles, à une API grand public sans contrat, sans paramétrage de confidentialité et sans information des personnes.[11][31]
Exploiter des données web pour entraîner un modèle d'IA maison	Respecter les robots.txt, balises « noai » et registres d'opposition, limiter les données collectées, documenter un intérêt légitime solide et une mise en balance favorable, mettre en œuvre anonymisation ou pseudonymisation.	
[39][14][^27]	Moissonner massivement des données personnelles sur des sites sans respecter les restrictions techniques ou contractuelles, sans base légale ni documentation, y compris des contenus sensibles ou privés.[39][30]	
Analyser les conversations de support client avec l'IA pour améliorer le service	Informer les clients de cette analyse, limiter les données utilisées, définir des durées de conservation, mettre en place une base légale (contrat ou intérêt légitime) et permettre l'exercice du droit d'opposition.[2][39][^5]	Utiliser toutes les conversations pour du profilage marketing ou des décisions automatisées sans information, sans base légale adaptée et sans possibilité d'opposition.[46][44]
Mettre en place une solution d'IA pour la détection de fraude	Fonder le traitement sur l'intérêt légitime ou l'obligation légale, réaliser une AIPD, limiter les données aux informations utiles, mettre en place des garanties (supervision humaine, tests de biais, documentation).[14][39][^18]	Utiliser un modèle opaque, sans documentation, qui affecte significativement les personnes (refus de service, blocage de compte) sans voie de recours ni explication.[43][36]

10. Conclusion opérationnelle

Pour un public d'entreprise non juriste, il est essentiel de retenir que le RGPD ne bloque pas l'usage de l'IA générative, mais impose de la mettre au service de finalités claires, d'éviter les collectes excessives et de respecter les droits des personnes. Les obligations légales portent sur la licéité des traitements, l'information, la sécurité, la documentation (registre, AIPD, contrats), et l'encadrement des décisions automatisées, tandis que les recommandations (chartes d'usage, déploiements on-premise, techniques avancées de confidentialité) renforcent la capacité de l'entreprise à démontrer sa conformité et à réduire les risques.[10][17][3][16][^11]

Les zones d'interprétation subsistent, notamment sur l'anonymisation effective des modèles, l'usage de l'intérêt légitime pour l'entraînement des IA, et la qualification de certaines décisions comme « automatisées » au sens de l'article 22. Dans ces cas, il est prudent d'adopter une approche conservative : associer le DPO et les experts techniques, multiplier les analyses de risques, documenter les arbitrages, et se référer aux avis et lignes directrices de la CNIL, du CEPD et de l'EDPB.[26][36][^14]

En pratique, une feuille de route opérationnelle pour une entreprise peut comprendre : l'inventaire des cas d'usage d'IA, la définition des finalités et bases légales, la mise en place de chartes d'usage et de formations, la réalisation des DPIA nécessaires, la mise à jour du registre des traitements et des mentions d'information, l'encadrement rigoureux des prestataires, ainsi que la mise en place de mécanismes de supervision humaine et de contrôle des biais pour toutes les décisions significatives.[9][8][^12]

References

1. Le règlement général sur la protection des données - RGPD - CNIL - Règlement (UE) 2016/679 du Parlement européen et du Conseil du 27 avril 2016, relatif à la protectio...
2. Règlement (UE) 2016/679 du 27 avril 2016 relatif à la protection des ... - RGPD - Règlement (UE) 2016/679 du 27 avril 2016 relatif à la protection des personnes physiques à l'...
3. Développement des systèmes d'IA : les recommandations de ... - CNIL - L'idée reçue selon laquelle le RGPD empêcherait l'innovation en intelligence artificielle en Europe ...
4. IA et RGPD : les recommandations de la CNIL à l'épreuve du droit - La CNIL rappelle que le RGPD s'applique pleinement aux traitements de données à caractère personnel ...
5. [PDF] guide - pratioue de sensibilisation au rgpd - CNIL - Il vous propose des clés de compréhension pratiques pour engager au sein de votre entreprise, petite...
6. Article 4 RGPD : 26 définitions clés pour les juristes - Swim Legal - L'article 4, paragraphe 1, définit la donnée à caractère personnel comme « toute information se rapp...
7. EDPB Guidelines on consent under the GDPR - activeMind.legal - As the updated guidelines reaffirm, consent must be freely given, and individuals must have a real c...
8. [PDF] Guide pratique RGPD - Sécurité des données personnelles ... - CNIL - La gestion des risques permet de déterminer les précautions à prendre « au regard de la nature des d...
9. IA et RGPD : les recommandations de la CNIL - Actecil Academy - Les recommandations · Détermination du régime juridique applicable : Identifier si le RGPD s'appliqu...

10. Développement des systèmes d'IA : les recommandations spécifiques - La CNIL a publié ses premières recommandations sur l'application du RGPD au développement des systèm...
11. RGPD & IA Générative : ce que dit la CNIL | Data Comply One - Quels sont les risques de l'IA générative au regard du RGPD ? · Hallucinations : contenus faux mais ...
12. Comment déployer une IA générative ? La CNIL apporte de ... - Mettre en œuvre une gouvernance adaptée pour s'assurer du bon respect du RGPD et de ces préconisatio...
13. Article 32 : Sécurité du traitement - GDPR.expert - 3. La réalisation de traitements en sous-traitance doit être régie par un contrat ou un acte juridiq...
14. Unwrapping the EDPB's Guidance on AI models and Data Protection - The EDPB's Opinion 28/2024 offers a robust framework for applying the GDPR to AI models, addressing ...
15. Modèles d'IA et RGPD : le CEPD publie son avis pour une IA ... - CNIL - Le CEPD considère que les modèles d'IA entrainés à partir de données personnelles ne peuvent pas par...
16. CHAPITRE IV - Responsable du traitement et sous-traitant - CNIL - Section 1 - Obligations générales · Article 24 - Responsabilité du responsable du traitement · Artic...
17. Article 30 RGPD. Registre des activités de traitement - GDPR-Text.com - Chaque responsable du traitement et sous-traitant devrait être tenu de coopérer avec l'autorité de c...
18. Privacy-by-Design and Privacy-by-Default in AI Systems - LinkedIn - The European Data Protection Board (EDPB) Guidelines 4/2019 provides further guidance on implementin...
19. CHAPITRE I - Dispositions générales - CNIL - Article 4 - Définitions. Aux fins du présent règlement, on entend par : «données à caractère personn...
20. Article 4 RGPD. Définitions - GDPR-Text.com - 1) «données à caractère personnel», toute information se rapportant à une personne physique identifi...
21. Article 4 RGPD - Definitions cles du RGPD - Leto.legal - Les données à caractère personnel sont toutes les informations se rapportant à une personne physique...
22. Donnée personnelle | CNIL - Une donnée personnelle est toute information se rapportant à une personne physique identifiée ou ide...
23. Une donnée à caractère personnel, c'est quoi - Question | CNIL - C'est toute information relative à une personne physique susceptible d'être identifiée, directement ...
24. [PDF] Qu'est-ce qu'une donnée à caractère personnel ? (Article 4 ... - Medef - Une donnée est donc à caractère personnel dès lors qu'elle permet d'identifier ou de rendre identifi...
25. RGPD : les obligations à connaître pour les PME - Clic Formalités - Certaines erreurs reviennent souvent dans les PME. Par exemple, beaucoup d'entreprises collectent tr...
26. EDPB Opinion 28/2024 on personal data processing in the context ... - This opinion addresses data protection concerns related to AI models. Requested by the Irish Data Pr...
27. Résumé de l'avis 28/2024 du CEPD sur le traitement des données à ... - Pour qu'un modèle d'IA soit considéré comme anonyme, la probabilité d'extraction directe et de régur...
28. Donnée sensible - CNIL - Les données sensibles forment une catégorie particulière des données personnelles. Ce sont des infor...
29. Ce que dit l'Article 9 du RGPD - Donnees sensibles - Leto.legal - Informations relatives à l'origine raciale ou ethnique, · Informations relatives aux opinions politi...

30. RGPD : Qu'est ce qu'une donnée sensible ? - francenum.gouv.fr - de la prétendue origine raciale ou ethnique, · des opinions politiques, · des convictions religieuse...
31. Comment la CNIL données sensible définit-elle ? - Dipeeo - Les données sensibles sont des informations personnelles jugées particulièrement sensibles. Elles pe...
32. Article 4 - EU RGPD - “Définitions” - 22) «autorité de contrôle concernée», une autorité de contrôle qui est concernée par le traitement d...
33. CHAPITRE IV - Responsable du traitement et sous-traitant - Le responsable du traitement et le sous-traitant veillent à ce que le délégué à la protection des do...
34. Article 24. Responsabilité du responsable du traitement - GDPR - Article 24. Responsabilité du responsable du traitement. 1. Compte tenu de la nature, de la portée, ...
35. Obligations en matière de protection des données personnelles ... - Le Règlement général sur la protection des données (RGPD) s'applique à toutes les entreprises qui ré...
36. [PDF] Automated Decision-Making Under the GDPR: - The data subject shall have the right not to be subject to a decision ... by the EDPB in its data pr...
37. Guidelines 3/2019 on processing of personal data through video ... - Guidelines 3/2019 on processing of personal data through video devices. PDF, 651.1 KB. Select other ...
38. Artificial intelligence | European Data Protection Board - Opinion 28/2024 on certain data protection aspects related to the processing of personal data in the...
39. Intelligence artificielle et RGPD : l'intérêt légitime face au ... - L'intérêt légitime demeure l'outil juridique le plus disponible pour développer des systèmes d'IA lo...
40. Art. 22 GDPR – Automated individual decision-making, including ... - The data subject shall have the right not to be subject to a decision based solely on automated proc...
41. GDPR Article 22: Automated individual decision-making, inclu - A data subject has the right to not be subject to a decision based solely on automated processing, i...
42. Automated decision-making and profiling - EDPB - European Union - During its first plenary meeting the European Data Protection Board endorsed the GDPR related WP29 G...
43. Décisions automatisées et droit d'accès : la CJUE consacre un - La prise de décisions automatisées, y compris le profilage, impose au responsable de traitement d'ob...
44. Données personnelles en entreprise : les erreurs à éviter - Évitez les 10 erreurs RGPD les plus sanctionnées par la CNIL : conformité, sécurité, consentement. P...
45. Les fiches pratiques IA - CNIL - La CNIL propose une liste des points à vérifier, issue de ses recommandations pour le développement ...
46. Automated Decision Making: Overview of GDPR Article 22 - Article 22 of the GDPR restricts solely automated decisions that produce legal effects or similarly ...